

Context: Insurance company named Insurance Inc offering vehicle insurance for individuals (clients are only individuals)

It wants one IT solution (created, hosted and maintained by the insurance company) for insurance of vehicles which:

- **Creates users**
- Through which users can **purchase insurances** for vehicles
- **Monitors through a GPS** solution the location of the vehicles in order for these (i) to always have a GPS signal, (ii) not to leave Romania.

It wants also a **gamification IT** solution (created, hosted and maintained by DevOps Inc) in which clients win prizes based on:

- Number of kilometres travelled since the last accident where the insurance policy was used
- Number of years for which the individual is a client of the insurance company (fidelity prizes)

Further, the clients can **share** within the app **the prizes with their friends** who also have a user in the gamification IT solution.

The clients can **invite friends** from the contacts in their mobile phones on which the gamification IT solution is installed.

For creating the gamification IT solution, Insurance Inc and DevOps Inc concluded an agreement mentioning that Insurance Inc sends the requirements to DevOps Inc and DevOps Inc ensures that the IT solution is designed and created.

1. Please identify the data processing activities (e.g. opening services for the clients, sharing data with third parties for a particular purposes), data subjects, types of personal and data controllers/data processors as follows:

Name of data processing activity	Name of data subject	Type of personal data	Data controller (if exists)	Data processor (if exists)
Create account	Insurance Inc clients	Name, email, address, phone number, CNP	Insurance Inc	-
Purchase insurance	Insurance Inc clients	License plate, identification number, insurance policy details	Insurance Inc	-
Vehicle monitoring	Insurance Inc clients Vehicles	GPS location, movement logs	Insurance Inc	-
IT gamification	Insurance Inc clients	No km travelled, years of loyalty	Insurance Inc	DevOps Inc
Share	Insurance Inc clients Friends	Prize details, friend's user details	Insurance Inc	-
Invite friends	Insurance Inc clients Friends	Phone number (from mobile phone)	Insurance Inc	-

2. Please create a brief/high-level diagram of the It architecture for the IT solutions, mentioning:
 - which data is held in the database of each IT solution
 - what data you think is necessary to be collected from the individuals or from the vehicles for each data processing (a. execution of contract, b. monitoring of vehicles, c. gamification)

- what data is transferred between the IT solutions

➤ Insurance Inc

- Data held in the database
 - Client information – name, email, address, phone number, CNP
 - Vehicle information – license plate, identification number
 - Insurance details – policy information, payment
 - GPS data – location, movement logs
- Data collected from the individuals/vehicles
 - Name, email, address, phone number, CNP, license plate, vehicle identification number – for contract
 - GPS data – for monitoring
- Data transferred to DevOps Inc
 - Number of kilometres – for gamification
 - Years of fidelity – for rewards

➤ DevOps Inc

- Data held in the database
 - Client information – name, email, phone number
 - Gamification information – kilometres, loyalty years, rewards
 - Friend's details – name, phone number
- Data collected from the individuals/vehicles
 - Kilometres, years of loyalty, prize – for gamification
 - Reward details, friend's details – for reward sharing
 - Contact list details – for invitations
- Data transferred to Insurance Inc
 - Reports on gamification

3. Please outline what specific aspects you want to implement/analyse for the following principles (concrete examples tailored to the application in this scenario have to be included, not just theory from the course):

a. Minimise/Separate/Abstract/Hide

- Minimise
 - GPS data is stored temporarily
 - For gamification the only collected data is kilometres
 - The gamification doesn't collect personal data of the client
- Separate
 - Client and vehicle data are stored separately, so vehicle monitoring doesn't expose personal data
 - GPS data and user's personal data are stored separately, so we won't have the risk of identifying the user
- Abstract
 - Instead of tracking the exact location, we better track the number of km travelled and use alerts when the client leaves Romania
- Hide
 - Hide CNP and payment details

b. Anonymisation and Pseudonymisation

- Anonymisation
 - when analysing user's behaviour, don't link the name, CNP
- Pseudonymisation
 - Instead of using real name, use ID's in gamification system

c. Inform

- Clear explanation about how GPS data is used

- d. Control
 - The user can deactivate GPS tracking
 - e. Implement
 - Encryption for sensitive data (CNP, payment details, GPS data)
 - f. Demonstrate
 - Transparency in terms of who can access the data through audit logs
4. What is the processing basis for Insurance Inc to obtain the data from clients about their contacts in the context of the gamification IT solution? Explain why.
- The processing basis for Insurance Inc to obtain the data from clients about their contacts in the context of the gamification IT solution is through consent. According to GDPR, Article 6(1)(a) (Fig 1), the company must request explicit consent before processing any personal data. Considering that this data is not necessary to sign the contract, explicit consent is required from the client. The clients must be informed on how their contacts data will be used and they can withdraw the consent any time.



Fig. 1